

STRIDE Threat Model & Control Specifications

Zero-Trust Secure Backend & Identity Threat Detection · Technical Documentation

STRIDE Threat Model: Zero-Trust Case-File Exchange

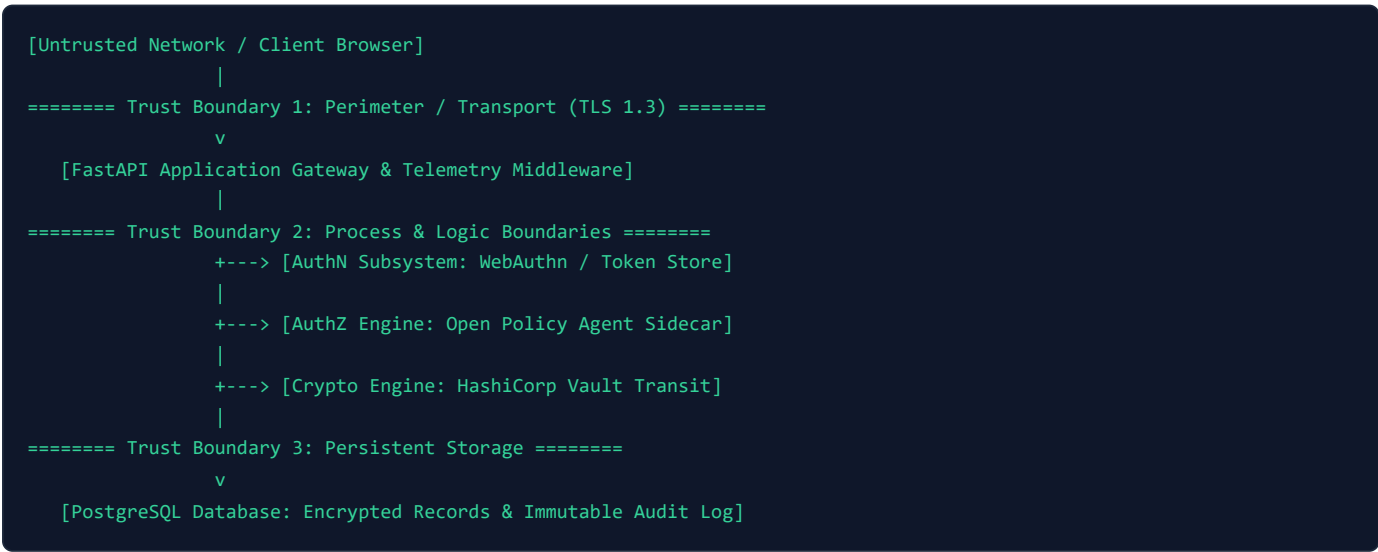
1. System Context & Overview

The **Zero-Trust Secure Evidence Exchange** provides a centralized, defense-in-depth platform for security analysts, incident responders, and compliance auditors to upload, exchange, and process sensitive case files, incident evidence, memory dumps, and forensic notes under stringent zero-trust guarantees.

Key Entities & Actors

- **Security Analyst:** Authorized operator creating and updating assigned case files and investigative notes.
- **Security Auditor:** Read-only actor reviewing case files and append-only audit trail logs.
- **System Administrator:** Operator managing user roles and system health.
- **Untrusted Client / Adversary:** External or compromised insider seeking unauthorized access, tampering, or data exfiltration.

2. Trust Boundaries & Data Flow Diagram (DFD)



3. STRIDE Threat Analysis

Category	Threat ID	Description & Vulnerability Scenario	Affected Asset / Schema	Impact	Planned Mitigation / Control
Spoofing	THR- SPOOF- 01	Stolen Access Token / Credential Replay: Adversary intercepts or replays a bearer access token or tries credential	users , src/auth/tokens/	Unauthorized session impersonation and identity takeover.	WebAuthn/Passkeys (FIDO2 public key auth), short-lived JWT access tokens (15m), rotating refresh tokens with token family lineage tracking, and IsolationForest anomaly detection.

Category	Threat ID	Description & Vulnerability Scenario	Affected Asset / Schema	Impact	Planned Mitigation / Control
		stuffing against weak authentication endpoints.			
Spoofing	THR-SP00F-02	Refresh Token Theft & Reuse: Adversary captures a long-lived refresh token and attempts to generate new access tokens.	refresh_tokens	Persistent unauthorized access to the case API.	Token Family Reuse Detection: Replay of an already-rotated refresh token immediately revokes the entire token family, invalidating all sessions for that lineage.
Tampering	THR-TAMP-01	Insecure Direct Object Reference (IDOR) & Case Mutation: An analyst maliciously modifies <code>case_files.id</code> payload or issues <code>PUT /cases/{id}</code> to modify a case file assigned to another analyst.	case_files.assigned_analyst_id , case_files.encrypted_content	Unauthorized modification or destruction of forensic evidence.	OPA Attribute-Based Access Control (ABAC): Evaluates <code>user.id == case.assigned_analyst_id</code> or role permissions in Rego policies before permitting update actions.
Tampering	THR-TAMP-02	Audit Log Tampering / Deletion: An insider attempts to alter or drop rows from the <code>audit_log</code> table to cover illicit activities.	audit_log	Loss of audit integrity and non-repudiation failure.	Append-only database constraints, strictly no <code>UPDATE / DELETE</code> API endpoints exposed, write-on-mutate middleware architecture.
Repudiation	THR-REP-01	Unattributed Action / Missing Actor Attribution: A user executes an unauthorized read or mutation on a sensitive <code>TLP:RED</code> case file without verifiable identity and IP binding in the audit log.	audit_log.actor_id , audit_log.timestamp , audit_log.client_ip	Inability to prove who accessed or altered evidence during forensic triage.	Mandatory audit logging on all mutating and sensitive read routes capturing <code>actor_id</code> , <code>actor_role</code> , <code>action</code> , <code>resource_id</code> , <code>client_ip</code> , and <code>timestamp</code> .
Information Disclosure	THR-INFO-01	Database Dump / Disk Storage PII Exfiltration: Direct compromise or	case_files.encrypted_content , case_files.encrypted_pii_subject	Major breach of sensitive intelligence, regulatory non-	HashiCorp Vault Envelope Encryption: Unique Data Encryption Key (DEK) per case file encrypted under Vault Key Encryption Key (KEK);

Category	Threat ID	Description & Vulnerability Scenario	Affected Asset / Schema	Impact	Planned Mitigation / Control
		snapshot extraction of the PostgreSQL database exposes sensitive forensic content and subject PII.		compliance (GDPR/HIPAA).	field-level encryption on <code>encrypted_pii_subject</code> .
Information Disclosure	THR-INFO-02	Authorization Policy Engine Bypass on Outage: When Open Policy Agent (OPA) sidecar crashes or network times out, backend logic erroneously falls back to permissive access.	<code>src/authz/</code>	Complete breach of RBAC/ABAC boundaries under denial-of-service conditions.	Fail-Secure Architecture: Hard requirement that any OPA error, non-200 status, timeout, or parsing error unconditionally results in an immediate <code>DENY</code> (<code>HTTP 403</code>).
Denial of Service	THR-DOS-01	Authentication Flood & MFA Push-Bombing: Automated adversary hammers authentication endpoints or floods verification requests to exhaust API workers or induce fatigue.	<code>src/auth/</code>	Service degradation and analyst fatigue leading to accidental approval.	Request rate limiting, session-level behavioral anomaly detection (<code>IsolationForest</code>), and cryptographic challenge-response binding.
Elevation of Privilege	THR-ELEV-01	Role Escalation via JWT Algorithm Confusion: Adversary crafts a forged JWT with <code>alg: none</code> or replaces the public key signature with an HMAC shared secret.	<code>src/auth/tokens/</code>	Attacker gains <code>admin</code> role and full case access.	Explicit verification of cryptographic signature algorithms, strict key validation, and SAST (Semgrep) scanning in CI.
Elevation of Privilege	THR-ELEV-02	Classification Boundary Escalation (TLP Bypass): An analyst cleared only for <code>TLP:GREEN</code> attempts to query or download <code>TLP:RED</code> case files.	<code>case_files.classification</code>	Unauthorized intelligence disclosure to uncleared personnel.	Fine-grained OPA ABAC policies enforcing classification clearance levels against user token attributes.

4. Trust Assumptions & Boundaries

1. **Vault & Database Co-location:** Vault and PostgreSQL run within protected internal infrastructure or container networks with mutual TLS / restricted VPC access.
2. **Sidecar Latency & Availability:** OPA is deployed as a local sidecar (`localhost:8181` / container network). When unreachable, the fail-secure rule must strictly prevent any request processing.
3. **Synthetic Data Policy:** All stored evidence, user names, and subject identifiers are 100% synthetic mock datasets to eliminate privacy and compliance risks.